

INFORMAÇÕES CADASTRAIS

NOME DA EMPRESA (FANTASIA - RAZÃO SOCIAL)	CNPJ
TELEFONE DA EMPRESA	SITE OFICIAL
NOME DO ENCARGADO (DPO)	E-MAIL DO ENCARGADO
NOME DO SUBSTITUTO DO ENCARGADO (DPO)	E-MAIL DO SUBSTITUTO
PONTO FOCAL NA UNIMED DO BRASIL	ENDEREÇO COMPLETO

INSTRUÇÕES PARA PREENCHIMENTO DOS QUESTIONÁRIOS

Este questionário tem como objetivo avaliar o nível de maturidade da sua empresa em privacidade e proteção de dados, e os resultados poderão ser prestados à Unimed do Brasil.

Em regra, devem ser preenchidas as abas:

- Privacidade;
- Inteligência Artificial;
- Segurança da Informação.

Importante: algumas abas podem conter orientações específicas com base nas respostas fornecidas. Por isso, leia atentamente o questionário e siga os direcionamentos indicados.

Para o correto preenchimento, considere:

- As respostas devem refletir a realidade atual da sua empresa;
- As informações das abas de Privacidade e Inteligência Artificial devem estar relacionadas ao produto ou serviço oferecido;
- Com relação à aba de Segurança da Informação, cada pergunta requer evidência;
- Não é necessário utilizar linguagem técnica, priorize respostas claras e objetivas;
- Em caso de dúvida, **recomendamos buscar apoio de profissionais da sua empresa com conhecimento em privacidade e segurança da informação.**

As informações fornecidas serão utilizadas como base para a avaliação de risco e maturidade, podendo impactar a classificação da Unimed do Brasil.

O preenchimento incorreto, incompleto ou inconsistente poderá comprometer a avaliação e resultar na não participação da Unimed do Brasil no processo de certificação.

Por fim, destacamos que a Unimed do Brasil é certificada nas normas ISO 27001 e ISO 27701, o que exige a adoção de práticas que garantam a segurança das informações e a proteção de dados pessoais em toda a cadeia.

Agradecemos a sua colaboração!

Equipe de Gestão da Privacidade de Dados da Unimed do Brasil

Dúvidas: encaminhe um e-mail para encarregado-igpd@unimed.coop.br

CONCEITOS

NCARREGADO (DPO)

JBSTITUTO DO ENCARREGADO (DPO)

OMERCIAL

ção de dados pessoais e segurança da informação, no contexto dos serviços que

o, leia atentamente as instruções ao longo do questionário

serviço que será prestado à Unimed do Brasil;

n privacidade de dados pessoais e/ou segurança da informação.

ictar o processo de homologação da sua empresa como

ção homologação.

adoção de critérios estruturados na avaliação de fornecedores,

- 1. Dado pessoal:** informação relacionada a pessoa natural identificada ou identificável;
- 2. Dado pessoal sensível:** dado pessoal sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural;
- 3. Titular de dados:** pessoa natural a quem se referem os dados pessoais que são objeto de tratamento;
- 4. Controlador:** pessoa natural ou jurídica, de direito público ou privado, a quem competem as decisões referentes ao tratamento de dados pessoais;
- 5. Operador:** pessoa natural ou jurídica, de direito público ou privado, que realiza o tratamento de dados pessoais em nome do controlador;
- 6. Encarregado:** pessoa indicada pelo controlador e operador para atuar como canal de comunicação entre o controlador e os titulares dos dados (ANPD);
- 7. Agentes de tratamento:** o controlador e o operador;
- 8. Tratamento de dados:** toda operação realizada com dados pessoais, como as que se referem a coleta, produção, redistribuição, processamento, armazenamento, eliminação, avaliação ou controle da informação, transferência de dados, bloqueio ou exclusão, entre outras;
- 9. Transferência internacional de dados:** transferência de dados pessoais para país estrangeiro ou organismo internacional;

iação a sindicato ou a organização de caráter religioso, filosófico ou político, dado

rentes ao tratamento de dados pessoais;

ssoais em nome do controlador;

o controlador, os titulares dos dados e a Agência Nacional de Proteção de Dados

dução, recepção, classificação, utilização, acesso, reprodução, transmissão,
ão, modificação, comunicação, transferência, difusão ou extração;

o internacional do qual o país seja membro.

QUESTIONÁRIO SOBRE PRIVACIDADE DE DADOS

Em razão de eventual prestação de serviço/produto, sua empresa realizará tratamento de dados pessoais?

Caso a resposta seja "NÃO", não é necessário preencher a aba "PRIVACIDADE". Basta seguir para as abas "INTELIGÊNCIA ARTIFICIAL" e "SEGURANÇA

Atenção: O preenchimento incorreto, incompleto ou inconsistente deste questionário preliminar poderá comprometer a avaliação e resultar na não

Durante a execução dos serviços para a Unimed do Brasil, qual das opções descreve como sua empresa trata os dados pessoais?

Justifique o cenário escolhido acima:

[escreva sua resposta]

Sobre a possível prestação de serviço/produto para Unimed do Brasil, responda:

O serviço prestado será a sustentação de infraestrutura tecnológica?

Caso a resposta seja "SIM", não é necessário responder às demais perguntas desta aba, mas verifique a instrução indicada no tópico "PRÓXIMOS PASSOS"

1. Quais dados serão tratados?

Caso tenha selecionado "Outro(s)", especifique: [escreva sua resposta]

2. Indique a qual(is) titular(es) o(s) dado(s) se refere(m):

Caso tenha selecionado "Outro(s)", especifique: [escreva sua resposta]

3. Indique quais ações serão realizadas com os dados pessoais (ex.: acessar, consultar, armazenar) e para qual finalidade?

4. Total de titulares cujos dados serão tratados:

5. Média do

ANÇA DA INFORMAÇÃO

?

DA INFORMAÇÃO".
homologação da sua empresa como fornecedora da Unimed do Brasil.

mpresa tratará dados pessoais?

SSOS", mais abaixo.

qual finalidade cada uma delas será utilizada (Ex.: Ação = visualização de dados pessoais / Finalidade = supc

volume de dados pessoais que serão tratados por titulares:

6. Média de duraç

--

--

--

orte ao software):

ção dos tratamento dos dados dos titulares:

7. Média da frequência com que os dados dos titulares serão tratados:

8. Extensão

9.1. Caso sua empresa utilize armazenamento ou tratamento de dados fora do Brasil, seria possível transf

10. Haverá decisões tomadas de forma automática (sem intervenção humana) com base em dados pessoa
[escreva sua resposta]

11. O tratamento de dados pessoais será realizado por meio de algum sistema específico ou por envio/rec
[escreva sua resposta]

12. Sua empresa utilizará inteligência artificial (IA) para tratar dados pessoais no contexto deste serviço?

PRÓXIMOS PASSOS

De acordo com a gestão de riscos de privacidade da Unimed do Brasil, o risco da sua empresa é

SIGA A INSTRUÇÃO ABAIXO:

[Caso esteja na instrução acima, clique aqui para acessar o questionário detalhado](#)

geográfica dos dados de titulares que serão tratados:

9. O armazenamer

erir essa operação para o Brasil para atender à Unimed do Brasil?

is? Se sim, explique qual decisão será tomada e em que contexto.

ebimento de informações por e-mail ou aplicativos de mensagem (ex.: WhatsApp, Teams etc.)? Se sim, info

nto dos dados pessoais é realizado fora do Brasil?

orme quais sistemas ou canais serão utilizados.

QUESTIONÁRIO PRELIMINAR SOBRE GOVERNANÇA DE INTELIGÊNCIA ARTIFICIAL

Considerando o produto ou serviço que será prestado, o presente questionário é aplicável à sua organização?

Caso a resposta seja "NÃO", não é necessário responder às demais perguntas da aba "Inteligência Artificial". Siga apenas para o preenchimento da aba "Privacidade e Segurança".

A solução de inteligência artificial é:

Informe quais modelos ou ferramentas de inteligência artificial são utilizados na solução:

Especifique conforme opção(ões) selecionada(s): [escreva sua resposta]

Entendimento da solução de inteligência artificial

1. Qual é a finalidade da solução de IA?

[escreva sua resposta]

2. Qual problema ela resolve?

[escreva sua resposta]

3. A solução toma decisões automatizadas que impactam pessoas?

3.1. Em caso positivo, quais decisões?

[escreva sua resposta]

Uso de agentes

1. A solução inclui agentes automatizados capazes de executar ações (ex.: enviar e-mails, acessar sistemas)?

Caso a resposta seja "SIM", responda às demais perguntas da seção "USO DE AGENTES". Caso a resposta seja "NÃO", siga para as demais seções ("Privacidade e Segurança").

2. Quais tipos de ações esses agentes podem executar? (ex.: envio de e-mails, consultas em banco de dados)

[escreva sua resposta]

3. Os agentes possuem apenas as permissões necessárias para sua função (princípio do menor privilégio)?

4. Ações sensíveis ou de maior impacto (ex.: envio de comunicações externas, transações, alterações de dados)?

ANÇA DA INFORMAÇÃO

Qual o seu nome?				

ba “Segurança da Informação”.

[illegible]

3, realizar consultas ou transações)?				

ADOS E PRIVACIDADE", "GOVERNANÇA E CONFIABILIDADE DA IA", "OPERAÇÃO E CONTI

os, acesso a sistemas internos, integrações via API etc.)

	Sim	Não	Não sabe	Total
Adicionalmente, os dados) exigem validação ou aprovação humana?	100%	0%	0%	100%

5. Como são controladas e protegidas as integrações com sistemas externos (ex.: APIs, bancos de dados, s
[escreva sua resposta]

Dados e Privacidade

1. Quais tipos de dados são tratados pela solução (incluindo dados pessoais e sensíveis)?

Caso tenha selecionado "Outro(s)", especifique: [escreva sua resposta]

2. Os dados, inclusive informações de negócio, fornecidos pelo cliente são utilizados para treinamento ou

2.1. Se sim: é possível optar por não utilizar os dados (opt-out)?

3. Onde os dados são armazenados e processados (país)?

[escreva sua resposta]

4. Como funciona a retenção e exclusão dos dados? (resposta descritiva curta)

[escreva sua resposta]

5. Existem medidas para garantir confidencialidade, integridade e disponibilidade?

5.1. Descreva brevemente:

[escreva sua resposta]

Governança e Confiabilidade da IA

1. O modelo foi testado e validado para sua finalidade?

2. Existe monitoramento contínuo de erros ou falhas?

3. A solução oferece explicação ou justificativa dos resultados?

4. Foram avaliados riscos de viés ou discriminação?

5. Existe possibilidade de revisão humana dos resultados?

6. O fornecedor pode reutilizar dados ou outputs gerados?

6.1. Se sim: explique

[escreva sua resposta]

Operação e Continuidade

istemas internos)?

melhoria do modelo?

|--|--|--|--|

Operação e Continuidade

1. Em caso de encerramento do contrato, o que acontece com os dados?

1.1. Explique a(s) opção(ões) selecionada(s):

[escreva sua resposta]

2. É possível exportar dados e logs?

3. Existe SLA de suporte?

3.1. Descreva

[escreva sua resposta]

Atenção: a depender das respostas fornecidas neste questionário, a área de Privacidade questionário complementar mais detalhado, com foco na governança de inteligência

[illegible]

QUESTIONÁRIO SOBRE SEGURANÇA DA INFORMAÇÃO		RESPOSTA
1	A empresa possui uma Política de Segurança da Informação formalizada e atualizada?	Sim
2	A empresa executa gestão de controle de acesso, contemplando: i. Todos os usuários, com níveis de permissão na proporção da necessidade dos respectivos trabalhos; ii. Funcionalidades no sistema de controle de acesso que possam detectar e não permitir o uso de senhas que não respeitem um certo nível de complexidade; iii. Adequado gerenciamento de senhas, estabelecendo controles como evitar o uso de senhas padrão disponibilizadas pelos fornecedores de software ou hardware adquiridos, utilizar apenas senhas complexas para acessar aplicativos e outros sistemas informáticos e não reutilizar senhas; iv. Aplicação do princípio do menor privilégio; v. Utilização de autenticação multifator para acessar sistemas ou base de dados que contenham dados pessoais; vi. Sistema de controle de acesso aplicável a todos os usuários que acessam o sistema de TI; vii. Existe controle de acesso físico às instalações onde os dados são processados/armazenados (catracas, câmeras, registro de visitantes)?	
3	A empresa possui mecanismos de proteção de terminais (endpoints), redes e servidores que contemplem: i. firewall de nova geração (Next-Generation Firewall) para proteção de rede? ii. o uso de antivírus/antimalware com atualização automática; iii. ferramentas de segurança de e-mail (AntiSpam e filtros); e iv. controles contra a transferência não autorizada de dados para dispositivos externos (pendrives e discos rígidos)?	
4	A empresa realiza backups regulares dos dados (Diário, Semanal, Mensal)?	
5	Os backups são testados periodicamente para garantir a recuperação dos dados?	

& SEGURANÇA DA INFORMAÇÃO

JUSTIFIQUE (Somente se não)	EVIDÊNCIA	
	Sim	





6	Existe um plano de continuidade de negócios e recuperação de desastres documentado e testado?	
7	Os colaboradores recebem treinamento anual sobre segurança da informação (phishing, senhas, proteção de dados)?	
8	A empresa possui acordo de confidencialidade (NDA) com todos os funcionários da empresa?	
9	Existe processo formal de gestão de incidentes de segurança (detecção, resposta, comunicação)?	
10	Os dados são criptografados durante transmissão (HTTPS, VPN, TLS) e em repouso (disco, backup)?	
11	A empresa possui controle para evitar a transferência de dados pessoais de estações de trabalho para dispositivos de armazenamento externo, como pendrives e discos rígidos externos?	
12	Existe processo de revisão periódica de acessos de usuários (trimestral ou semestral)?	
13	A empresa realiza testes de vulnerabilidade ou análise de segurança (pentest, scan de vulnerabilidades)?	
14	Existe política e processo para descarte seguro de mídias e equipamentos (destruição, sanitização)?	
15	Sobre serviço de nuvem: a empresa possui contrato de acordo de nível de serviço com o provedor de serviços em nuvem, contemplando a segurança dos dados armazenados?	

Sobre o preenchimento deste questionário

As respostas fornecidas neste questionário serão utilizadas para avaliar o nível de maturidade em segurança e compõem a análise de risco exigida pelo nosso processo de homologação de fornecedores.

Por esse motivo, cada pergunta requer uma evidência — um documento, print, política, relatório ou descrição prática declarada. Respostas acompanhadas de evidência têm maior peso na avaliação final. Respostas sem evidência têm peso reduzido.

O objetivo é entender a realidade da sua organização. Uma resposta parcial bem evidenciada tem mais valor na comprovação.

.
. .
. .
. .
a da informação da sua organização
. .
. .
ção do processo — que comprove a
1 evidência são consideradas, porém
. .
. .
or do que uma resposta positiva sem
. .
. .

